

IRB Disclosure Memorandum

Web Browsing and Tracking Study

Study: Measurement of Web Application Firewall (WAF) and Anti-Bot Signal Prevalence Across Public Websites

1. Purpose of This Memorandum

This memorandum is submitted to the Institutional Review Board (IRB) to disclose, in full technical detail, the categories of data collected by the browser extension used in this study, and to affirm that the study does not collect personally identifiable information (PII) about research participants. It is intended as a supporting document to the full protocol submission.

2. Study Summary

The research measures how different web application firewalls (WAFs), content delivery networks (CDNs), and anti-bot/CAPTCHA systems behave across a sample of public websites ($N = 400$), stratified into categories by the level of security/anti-bot measures they implement. Human participants ($M = 30$), recruited through Amazon Mechanical Turk (MTurk), are used to generate authentic, human-driven browser traffic, because many anti-bot systems specifically distinguish automated (headless/scripted) traffic from genuine human browsing. Each participant is assigned a subset of N/M websites and instructed to:

- Visit each assigned website and browse at least 10 subpages per site.
- Use only an unmodified, standard Chromium-based browser.
- Disable any VPN or proxy service during the session.
- Start from a clean browser profile (cookies, history, and cache cleared).
- No additional extension or adblocker may be active at the same time

The unit of analysis is the website (its WAF/anti-bot behavior), not the participant. The participant's role is solely to generate a human browsing session; no aspect of the study is designed to learn about the participant as an individual.

3. Description of Collected Data

The extension collects only technical, connection- and page-level signals related to the target website's own security stack. The table below lists every event type transmitted from the extension to the research upload server.

Event / Endpoint	Fields Collected	Source	Contains PII?
VISIT_START	Randomly generated visit_id (UUID), target URL, timestamp	Browser navigation event	No
WAF_PASSED	visit_id, URL, detected WAF/CDN vendor (e.g., Cloudflare, Akamai), HTTP status, timestamp	HTTP response headers	No

BLOCK_DETECTED	visit_id, URL, HTTP status code, matched anti-bot/CAPTCHA selector names, page title, element visibility flag, timestamp	HTTP status + page DOM	No (page title of target site may appear; not participant-identifying)
JS_API_CALL	visit_id, source script URL, invoked browser/JS API name and arguments used for fingerprinting detection	Instrumented JavaScript API calls made by the visited site's own code	No
log_network (response body)	visit_id, URL, HTTP status, MIME type, raw response body text (HTML/JS/JSON only; capped at 256 KB; images, video, audio, fonts, and binary/archive types excluded)	Network response bodies of the visited (third-party) site	No participant PII; see Section 5 on incidental content
MTurk ID		Entered by participants to later be verified to be eligible for payment	Not PII, as MTurk ids are pseudoanonymous. Will be discarded after eligibility for compensation is confirmed.

Each browsing session (a single visit to a study website) is tagged with a randomly generated visit_id (a UUID created client-side per navigation). This identifier links events within one session for analysis purposes only, it is not derived from and cannot be traced back to any participant-identifying information, and it is not the same value across sessions or participants.

4. What is Not Collected

The following table addresses categories of information commonly of concern in human-subjects research involving software instrumentation, and confirms their status in this study.

Category	Status
Participant name, email	Not stored by the extension or research server. Compensation and worker eligibility are handled entirely within MTurk's own platform, outside the study's data pipeline.
Demographic information (age, gender, location, etc.)	Not collected.
Login credentials, passwords, or authentication tokens	Not collected. Participants use a clean, logged-out browser profile; no form or credential capture logic exists in the extension.
Cookies or session identifiers	Not collected or transmitted.
Keystrokes, mouse movement, or clipboard content	Not collected. The extension has no input-logging functionality.

Browsing history outside the assigned study URL list	Not collected. Logging is scoped to a fixed target-domain list loaded from the study's site manifest.
Device identifiers, IP address, or geolocation	Not intentionally collected by the extension. (Any IP address visible to the upload server as a byproduct of standard HTTP transmission is treated as connection metadata, not linked to identity, and is discussed in Section 6.)
Microphone, camera, or other sensor data	Not accessed. The extension requests no such permissions.

5. Incidental Content in Captured Response Bodies

To detect WAF challenge pages and anti-bot markup, the extension logs the text of HTTP response bodies returned by the visited (third-party) websites themselves, i.e., the HTML/JS/JSON content those sites serve to any visitor. Because participants browse in a clean, logged-out profile with no account created on the target sites, these pages reflect generic/anonymous visitor content rather than personalized or account-specific content. No response body is authored by or contains information about the participant; any information present is content the target website serves publicly to unauthenticated visitors. As an additional safeguard, response bodies are capped at 256 KB and image/video/audio/font/binary responses are excluded, further limiting incidental capture to markup and script content relevant to the detection task.

6. Network- and Platform-Level Metadata

As with any client-server data transmission, the research upload server will, as a function of the HTTP/TLS protocol itself, observe the source IP address of each request. This is standard server-log metadata rather than data the extension is designed to collect, and the study team will not use it to identify participants. Similarly, participant recruitment and compensation are handled entirely within MTurk's platform.

7. Data Security and Retention

- Data is transmitted over HTTPS to a study-controlled server; no data is written to or retained on the local machine beyond the duration of the browsing session.
- Collected data will be stored on [research institution] secured storage, accessible only to the study research team.
- Data will be retained for [retention period, e.g., 3 years post-publication, per institutional policy] and then deleted.
- Collected MTurk IDs will be discarded after eligibility for payment has been confirmed
- No dataset produced by this study will be published or shared containing participant-linkable identifiers.

8. Summary Statement for the Record

The research team affirms that this study's browser extension is designed and scoped to collect only website-side technical security signals (HTTP headers, status codes, anti-bot DOM markers,

and response bodies of the third-party sites visited) tied to a session-scoped random identifier. It does not collect participant names, contact information, demographic data, credentials, cookies, keystrokes, or MTurk Worker IDs, and browsing is restricted to a fixed, pre-approved list of study websites. Accordingly, the research team requests that the IRB confirm this study does not involve the collection of personally identifiable information about human subjects.